Week 10-11
Lecture (W10) - IDPS (Ref: NIST SP 800-94)
Lab 5 (W11) - IDS

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL

(Reference : https://csrc.nist.gov/pubs/sp/800/94/final)

IDPS Technologies - Typical Components (P.23/127)

- Sensor or Agent
  - Monitor and Analyze activity
  - Sensor : used for IDPSs monitoring networks, including network-based, wireless, and network behavior analysis technologies.
  - Agent : used for host-based IDPS technologies.
- Management Server
  - A centralized device receiving information from the sensors or agents and manages them. Some management servers perform event analysis identification.
  - Matching event information from multiple sensors or agents, such as finding events triggered by the same IP address, is known as correlation.
  - Available as both appliance and software-only products.
- Database Server
  - A repository for event information recorded by sensors, agents, and/or management servers.
  - Many IDPSs provide support for database servers.
- Console
  - A program providing an interface for the IDPS's users and administrators. Console software is typically installed onto standard desktop or laptop computers. Some consoles are used for IDPS administration only, such as configuring sensors or agents and applying software updates, while other consoles are used strictly for monitoring and analysis. Some IDPS consoles provide both administration and monitoring capabilities.

IDPS Technologies - Network Architecture (P.23/127)

All components may be designed to connect via either Out-of-Band or InBand chennel.

- Isolated management network (Out-of-Band)
  - Each sensor/agent host has an additional network interface (i.e., management interface) connecting to management network.
  - Each sensor/agent host is unable to pass any traffic between them.
  - Management servers, database servers, and consoles are attached to the management network only.
  - Effectively isolates the management network from the production networks.
  - Advantages
    - To conceal the existence and identity of the IDPS from attackers;
    - To protect the IDPS from attack;
    - To ensure that the IDPS has adequate bandwidth to function under adverse conditions
  - DisadvantagesA
    - Additional costs in networking equipment and other hardware (e.g., PCs for the consoles)
    - Inconvenience for IDPS administrators of using separate computers for IDPS management and monitoring.
- Mixed production network (InBand).
  - If an IDPS is deployed without a separate management network, another way of improving IDPS security is to create a virtual management network using a virtual local area network (VLAN) within the standard networks.
  - Using a VLAN provides protection for IDPS communications, but not as much protection as a separate management network.
  - For example, misconfiguration of the VLAN could lead to the exposure of IDPS data.
  - Another concern is that under adverse conditions, such as DDoS attacks or major malware incidents, the network devices shared by the organization's primary networks and VLAN might become completely saturated, negatively impacting the availability and performance of the IDPS.

IDPS Technologies - Security Capabilities (P.24/127)

Information Gathering Capabilities

Logging Capabilities

Detection Capabilities
- Thresholds
- Blacklists and Whitelists
- Alert Setting
  - Most IDPS technologies allow administrators to customize each alert type.
  - Examples of actions that can be performed on an alert type include the following:
    - Toggling it on or off
    - Setting a default priority or severity level
    - Specifying what information should be recorded and what notification methods (e.g., e-mail, pager) should be used
    - Specifying which prevention capabilities should be used.
- Code Viewing and Editing
  - Some IDPS technologies permit administrators to see some or all of the detection-related code. This is usually limited to signatures, but some technologies allow administrators to see additional code, such as programs used to perform stateful protocol analysis.

Prevention Capabilities
- Multiple prevention capabilities; the specific capabilities vary by IDPS technology type.
- IDPSs usually allow administrators to specify the prevention capability configuration for each type of alert.
- Specifying which type of prevention capability should be used.
- Allows administrators to monitor and fine-tune the configuration of the prevention capabilities before enabling prevention actions, which reduces the risk of inadvertently blocking benign activity.

IDPS Technologies - Management (P.26/127)

Architecture Design

- Where the sensors or agents should be placed
- How reliable it should be and what measures should be used to achieve that reliability
  - such as having multiple sensors monitor the same activity in case a sensor fails, or using multiple management servers so that a backup server can be used in case the primary server fails
- Where the other components of the IDPS will be located (e.g., management servers, database servers, consoles), and how many of each component are needed to achieve the necessary usability, redundancy, and load balancing goals
- With which other systems the IDPS needs to interface
  - Systems to which it provides data, such as security information and event management software, centralized log servers, e-mail servers, and paging systems
  - Systems on which it initiates prevention responses (e.g., firewalls, routers, switches)
  - Systems that manage IDPS components, such as network management software (for a management network) or patch management software (for keeping consoles' operating systems and applications fully up-to-date)
- Whether or not a management network will be used
- What other security controls and technologies need to be altered to accommodate IDPS deployment

IDPS Technologies - Management (2) (P.27/127)

Component Testing and Deployment

- ควร Test ก่อน Deploy ลง Production

Securing IDPS Components

- ควรแยก Account ตามหลัก Sepatation of Duties และให้สิทธิตาม Least Privilege
- Access Control การเข้า Config Mode ป้องกันการเข้าถึง Sensitive Info. ที่ถูกเก็บใน IDPS
- Access Control ช่องทางการสื่อสาร แต่จะให้ดีที่สุดคือใช้ OOB (ต้องแลกกับ additional cost)

Operation and Maintenance

- Typical Use
- Ongoing Solution Maintenance
- Acquiring and Applying Updates : Software Updates and Signature Updates

Building and Maintaining Skills

- Vendor Training
- Product Documentation
- Technical Support
- Professional Services
- User Communities

IDPS Technologies - Network-Based IDPS (P.36/127)

Analysis Based on 4 TCP/IP Layers:

- Application Layer
- Transport Layer
- Network Layer :
  - Source IP Addresses
  - Destination IP Addresses
  - IP Protocol Number
- Hardware Layer
  - MAC Addresses

Application Layer. This layer sends and receives data for particular applications, such as Domain Name System (DNS), Hypertext Transfer Protocol (HTTP), and Simple Mail Transfer Protocol (SMTP).
Transport Layer. This layer provides connection-oriented or connectionless services for transporting application layer services between networks. The transport layer can optionally ensure the reliability of communications. Transmission Control Protocol (TCP) and User Datagram Protocol (UDP) are commonly used transport layer protocols.
Internet Protocol (IP) Layer (also known as Network Layer). This layer routes packets across networks. IPv4 is the fundamental network layer protocol for TCP/IP. Other commonly used protocols at the network layer are IPv6, Internet Control Message Protocol (ICMP), and Internet Group Management Protocol (IGMP).
Hardware Layer (also known as Data Link Layer). This layer handles communications on the physical network components. The best known data link layer protocol is Ethernet.

Figure 4-1. TCP/IP Layers

Typical Components

- Appliance (i.e., specialized hardware+sensor software)
- Software Only

Network Architectures and Sensor Locations (P.38/127)

Inline

An inline sensor is deployed so that the network traffic it is monitoring must pass through it, much like the traffic flow associated with a firewall.

Passive

A passive sensor is deployed so that it monitors a copy of actual network traffic; no traffic actually passes through the sensor.

Passive sensors can monitor traffic through various methods, including the following:

1. Spanning Port

2. Network Tap
   A direct connection between a sensor and the physical network media itself, such as a fiber optic cable. The tap provides the sensor with a copy of all network traffic being carried by the media.

3. IDS Load Balancer
   Send all traffic to multiple IDPS sensors

   Dynamically split the traffic among multiple IDPS sensors based on volume.

   Split the traffic among multiple IDPS sensors based on IP addresses, protocols, or other characteristics

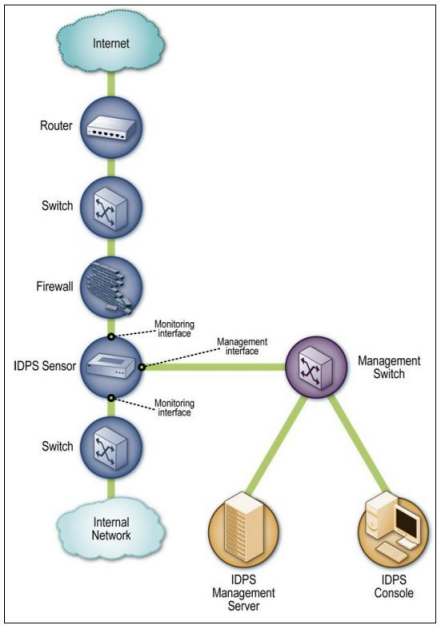


Figure 4-2. Inline Network-Based IDPS Sensor Architecture Example

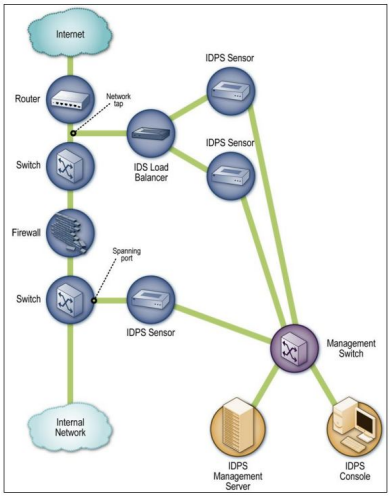


Figure 4-3. Passive Network-Based IDPS Sensor Architecture Example

Security Capabilities (P.41/127)

Information Gathering Capabilities

- Identifying Hosts, Operating Systems, Applications, and Network Characteristics

Logging Capabilities

- Timestamp (usually date and time)
- Connection or session ID
    - Typically a consecutive or unique number assigned to each TCP connection or to like groups of packets for connectionless protocols)
- Event or alert type
- Rating (e.g., priority, severity, impact, confidence)
- Network, transport, and application layer protocols
- Source and destination IP addresses
- Source and destination TCP or UDP ports, or ICMP types and codes
- Number of bytes transmitted over the connection
- Decoded payload data, such as application requests and responses
- State-related information (e.g., authenticated username)
- Prevention action performed (if any)

Detection Capabilities (P.43/127)

Application Layer Reconnaissance and Attacks
(e.g., banner grabbing, buffer overflows, format string attacks, password guessing, malware transmission)

Most network-based IDPSs analyze several dozen application protocols. Commonly analyzed ones include DHCP, DNS, Finger, FTP, HTTP, IMAP, IRC, NFS, POP, rlogin/rsh, RPC, SIP, SMB, SMTP, SNMP, Telnet, and TFTP, as well as database protocols, IM applications, and P2P file sharing software.

Transport Layer Reconnaissance and Attacks (e.g., port scanning, unusual packet fragmentation, SYN floods)

The most frequently analyzed transport layer protocols are TCP and UDP.

Network Layer Reconnaissance and Attacks (e.g., spoofed IP addresses, illegal IP header values)

The most frequently analyzed network layer protocols are IPv4, ICMP, and IGMP. Many products are also adding support for IPv6 analysis.

Unexpected Application Services (e.g., tunneled protocols, backdoors, hosts running unauthorized application services)

Usually detected through stateful protocol analysis methods, which can determine if the activity in a connection is consistent with the expected application protocol, or through anomaly detection methods, which can identify changes in network flows and open ports on hosts.

Policy Violations (e.g., use of inappropriate Web sites, use of forbidden application protocols)

Some types of security policy violations can be detected by IDPSs that allow administrators to specify the characteristics of activity that should not be permitted, such as TCP or UDP port numbers, IP addresses, Web site names, and other pieces of data that can be identified by examining network traffic.

Prevention Capabilities (P.46/127)

Passive Only

Ending the Current TCP Session

A passive sensor can attempt to end an existing TCP session by sending TCP reset packets to both endpoints; sometimes called *session sniping*. The sensor does this to make it appear to each endpoint that the other endpoint is trying to end the connection. The goal is for one of the endpoints to terminate the connection before an attack can succeed. Unfortunately, in many cases the reset packets are not received in time because the attack traffic has to be monitored and analyzed, the attack detected, and the packets sent across networks to the endpoints. Also, since this technique is only applicable to TCP, it cannot be used for attacks carried in other types of packets, including UDP and ICMP. Session sniping is not widely used any more because other, newer prevention capabilities are more effective.

Inline Only

Performing Inline Firewalling

Most inline IDPS sensors offer firewall capabilities that can be used to drop or reject suspicious network activity.

Throttling Bandwidth Usage

If a particular protocol is being used inappropriately, such as for a DoS attack, malware distribution, or peer-to-peer file sharing, some inline IDPS sensors can limit the percentage of network bandwidth that the protocol can use. This prevents the activity from negatively impacting bandwidth usage for other resources.

Altering Malicious Content

Some inline IDPS sensors can sanitize part of a packet, which means that malicious content is replaced with benign content and the sanitized packet sent to its destination. A sensor that acts as a proxy might perform automatic normalization of all traffic, such as repackaging application payloads in new packets. This has the effect of sanitizing some attacks involving packet headers and some application headers, whether or not the IDPS has detected an attack. Some sensors can also strip infected attachments from e-mails and remove other discrete pieces of malicious content from network traffic.

Both Passive and Inline

Reconfiguring Other Network Security Devices

Many IDPS sensors can instruct network security devices, e.g., FWs, routers, and switches to reconfigure themselves to block certain types of activity or route it elsewhere.

Running a Third-Party Program or Script

Some IDPS sensors can run an administratorspecified script or program when certain malicious activity is detected. This could trigger any prevention action desired by the administrator, such as reconfiguring other security devices to block the malicious activity. Third-party programs or scripts are most commonly used when the IDPS does not support the prevention actions that administrators want to have performed.

Network-Based IDPS - Management

Architecture Design

A consideration specific to network-based IDPSs is where the sensors should be placed on the network, which includes deciding how many sensors are needed, which sensors should be inline and which should be passive, and how passive sensors should be connected to the network (e.g., IDS load balancer, network tap, switch spanning port).

Component Testing and Deployment

Implementing a network-based IDPS can necessitate brief network outages, particularly when deploying inline sensors. However, passive sensor deployment can also cause outages for several reasons, including installation of network taps and IDS load balancers, and reconfiguration of switches to activate spanning port functions.

Securing the IDPS Components

Administrators should ensure that for both passive and inline sensors, IP addresses are not assigned to the network interfaces used to monitor network traffic, except for network interfaces also used for IDPS management.

Operating a sensor without IP addresses assigned to its monitoring interfaces is known as operating in stealth mode. Stealth mode improves the security of the IDPS sensors because it prevents other hosts from initiating connections to them. This conceals the sensors from attackers and thus limits their exposure to attacks.

However, attackers may be able to identify the existence of an IDPS sensor and determine which product is in use by analyzing the characteristics of its prevention actions. Such analysis might include monitoring protected networks, and determining which scan patterns trigger particular responses and what values are set in certain packet header fields.

Examples of IDPS in Practices

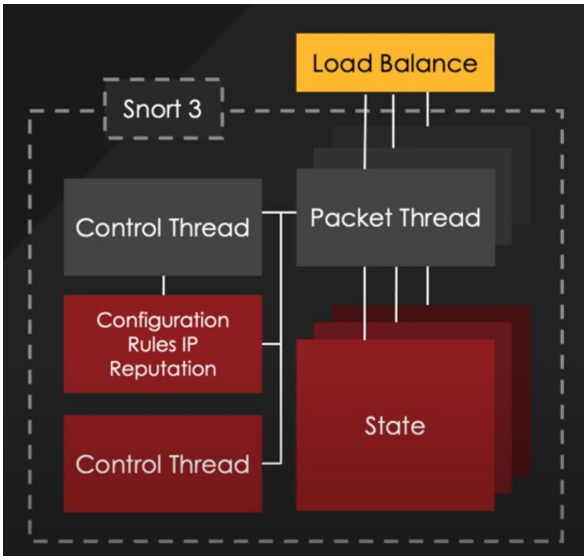
Snort

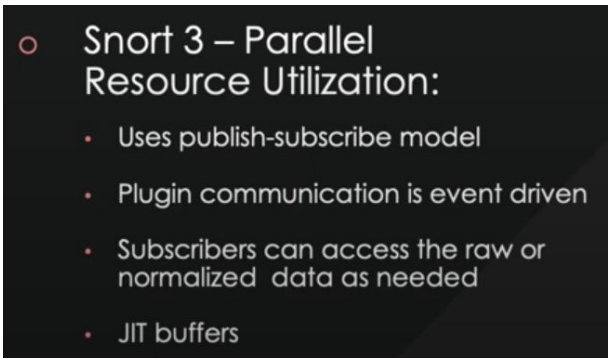
- https://www.snort.org/
- https://github.com/snort3/snort3

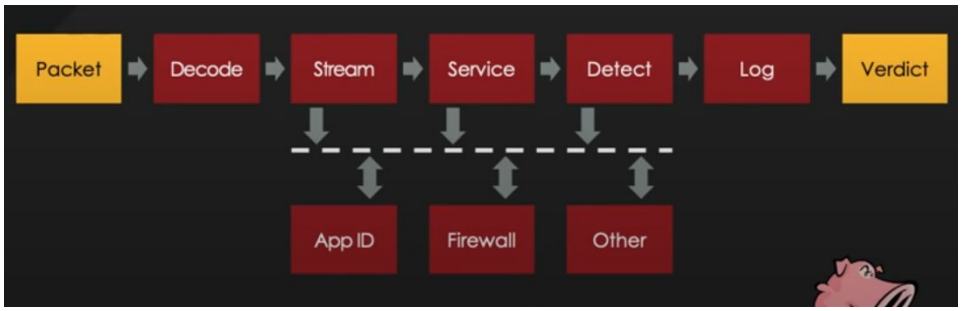
Suricata

- https://suricata.io/
- https://github.com/OISF/suricata

Snort3 Architecture







Credit: Snort 3 and Me: An introduction and overview to Snort 3

https://youtu.be/OYBje_JxZzE?si=Q_C4JTPmYr9MoYgn

Lab 5 : IDS

Lab 5-A : Passive IDS for Ping and Remote Access Detections

Lab 5-B : Passive IDS for Nmap Detection

Lab 5-C : Passive IDS for DoS Detection

Lab 5-D : Inline IDS for DoS Detection

เลือก IDS ตามใจชอบ
- Snort
- Suricata
- ...

Lab 5-A : Passive IDS for Ping and Remote Access Detections

1. ติดตั้ง IDS ดังรูป คอนฟิกและ Start IDS Service ให้ตรวจจับการ Ping แล้วลองสั่ง Ping จาก Attacker ไป Web Server

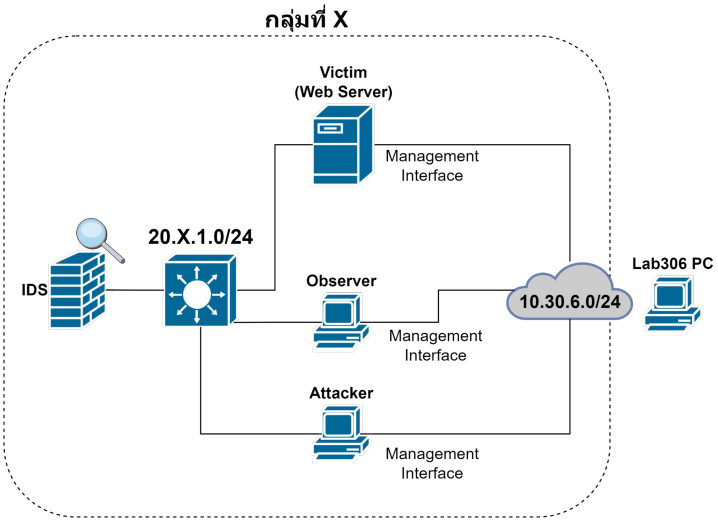
2. บันทึก IDS Rules และผลการ Detect จาก IDS

3. คอนฟิกและ Start IDS Service ให้ตรวจจับการ Telnet และ FTP แล้วสั่ง Telnet และ FTP จาก Attacker ไป Web Server

4. บันทึก IDS Rules และผลการ Detect จาก IDS

5. อธิบายว่าต้องกำหนด IDS Rules อย่างไรจึงจะสามารถ Detect การ Ping และการ Remote Access ดังกล่าวได้

6. อธิบายวิธีคอนฟิก Network ว่าใช้วิธีใดให้ IDS ได้รับ Traffic มาทำการตรวจสอบ



Lab 5-B : Passive IDS for Nmap Detection

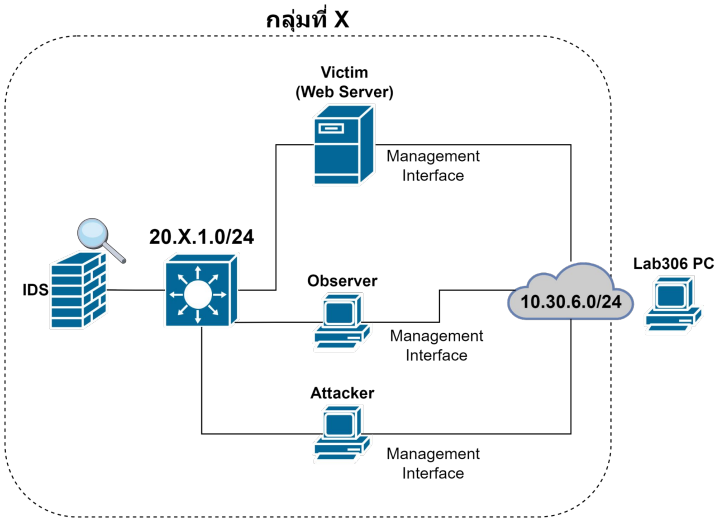
1. ติดตั้ง IDS ดังรูป คอนฟิกและ Start IDS Service ให้ตรวจจับการทำ Port Scanning

2. ให้ Observer ใช้ Iperf สร้าง Traffic ปกติ ส่งไป Web Server

3. ให้ Attacker ทำ Port Scanning ไปยัง Web Server

4. บันทึก IDS Rules และผลการ Detect จาก IDS

5. อธิบายว่าต้องกำหนด IDS Rules อย่างไรจึงจะสามารถ Detect การทำ Port Scanning ได้



Lab 5-C : Passive IDS for DoS Detection

1. ติดตั้ง IDS ดังรูป คอนฟิกและ Start IDS Service ให้จับ ICMP Flood, UDP Flood, และ TCP SYN Flood

2. ให้ Observer ใช้ Iperf สร้าง Traffic ปกติ ส่งไป Web Server

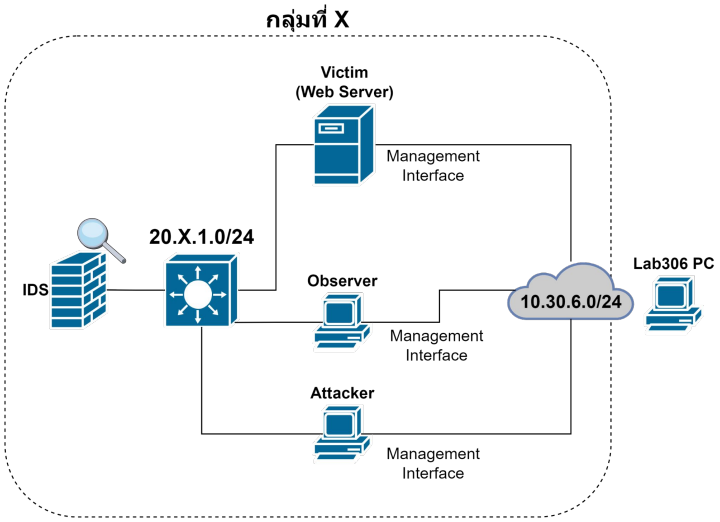
3. ให้ Attacker ทำการ hping3 ไปยัง Web Server แบบ ICMP Flood, UDP Flood, และ TCP SYN Flood

4. บันทึก IDS Rules และผลการ Detect จาก IDS

5. อธิบายว่าต้องกำหนด IDS Rules อย่างไรจึงจะสามารถ Detect แต่ละการโจมตีที่ทำการทดลองไปได้

6. ถ้าต้องการให้เก็บผลลง Local Log File ต้องทำอย่างไร

7. ถ้าต้องการให้ส่งผลไป Centralized Log Server ต้องทำอย่างไร



คำถามท้าย Lab 5

ให้สรุปขั้นตอนการ Setup IDS เพื่อให้ตรวจจับ Security Incident ว่ามีกี่ขั้นตอนอะไรบ้าง และให้อธิบายหลักการกำหนด IDS Rules พร้อมยกตัวอย่าง และให้ นศ เก็บเอกสารนี้ไว้ต่างหากเพราะอาจจะเป็นเอกสารชิ้นเดียวที่จะอนุญาตให้นำเข้าในการสอบภาคปฏิบัติได้

Lab 5-D : Inline IDS for DoS Detection (Option)

1. ติดตั้ง IDS ดังรูป คอนฟิกและ Start IDS Service

2. ให้ Observer ใช้ Iperf สร้าง Traffic ปกติ ส่งไป Web Server

3. ให้ Attacker ทำการ hping3 ไปยัง Web Server แบบ ICMP Flood, UDP Flood, และ TCP SYN Flood

4. บันทึก IDS Rules และผลการ Detect จาก IDS

5. อธิบายวิธี Setup ทั้ง Network ว่าแตกต่างจากแบบ Passive IDS อย่างไร

